

Repartir, rotar y tokenizar

Treinta minutos en clase; los minutos de cada ejercicio son un ritmo sugerido y el docente gestiona el tiempo, así que lo que no se cierre en el aula continúa como trabajo independiente. Los tres ejercicios corren en su navegador, sin conexión: reparto de secreto de Shamir, rotación de llave maestra sin recifrar, y tokenización. El ejercicio en Python, con pycryptodome, está al final.

Antes de empezar. No se evalúa que el código corra. Se evalúa que expliquen **por qué cada técnica resuelve un hallazgo concreto del caso**: Shamir para las llaves de los cajeros, la rotación para la llave maestra, la tokenización para el archivo de analítica.

EJERCICIO 1 • 10 MINUTOS

Repartir la llave de los cajeros

La llave de los cajeros la tiene hoy una sola persona, de hecho, sin custodios. Con un umbral de tres, repártanla entre cinco custodios: harán falta tres para reconstruirla, y con dos no se obtiene **nada**. Ese último punto es el que hay que ver con los ojos.

LA LLAVE DE LOS CAJEROS (128 BITS)

—

REPARTIR 3 DE 5

RECONSTRUIR • MARQUEN LAS PARTES QUE ENTREGAN

Panel interactivo • ábralo en el navegador para ejecutarlo

Por qué con dos partes no sale «casi» la llave, sino nada

Cada byte de la llave es el término independiente de un polinomio secreto de grado dos —una parábola en aritmética de campo finito—. Cada custodio recibe un punto de esa parábola. Con tres puntos hay una sola parábola que pasa por ellos, así que el término independiente queda determinado: se recupera la llave. Con dos puntos pasan **infinitas** parábolas, una por cada valor posible del secreto, y todas son igual de probables. Por eso dos custodios no obtienen una versión aproximada: obtienen un valor que no tiene ninguna relación con la llave real. Compruébenlo marcando solo dos partes.

QUÉ SE ENTREGA DE ESTE EJERCICIO

- La reconstrucción correcta con tres partes y el resultado sin sentido con dos.
- Una frase: cómo cambia el hallazgo H6 —«las llaves las tiene quien las necesitó»— si se reparten así entre custodios.

EJERCICIO 2 • 10 MINUTOS

Rotar la llave maestra sin tocar los datos

«Rotar llaves es inviable, habría que recifrarlo todo.» Este ejercicio demuestra que no. Se cifran los datos con una llave de datos (DEK), y la DEK se guarda envuelta bajo una llave maestra (KEK). Rotar la maestra vuelve a envolver la DEK: cambian **40 bytes**, y ni un solo registro se recifra.

MIL REGISTROS CIFRADOS EN SOBRE

ROTAR LA LLAVE MAESTRA

Panel interactivo • ábralo en el navegador para ejecutarlo

Qué es cifrado en sobre, en una imagen

Imaginen mil cajas cerradas con la misma llave pequeña, la DEK. Esa llave pequeña se guarda dentro de una caja fuerte, la KEK. **Rotar** la llave maestra es cambiar la caja fuerte y mover la llave pequeña de la vieja a la nueva: las mil cajas siguen cerradas con la misma llave pequeña, intactas. Recifrar todo sería abrir las mil cajas y volver a cerrarlas con otra llave —lo que nadie quiere hacer, y por eso no se rota nunca en Coopaburrá—. Con este diseño, rotar cuesta 40 bytes.

QUÉ SE ENTREGA DE ESTE EJERCICIO

- Los dos números: cuántos bytes cambiaron al rotar frente al tamaño total de los datos.
- Una frase para el que dice que rotar es inviable, usando esos dos números.

EJERCICIO 3 • 10 MINUTOS

Tokenizar las cédulas del archivo de analítica

El área de analítica necesita cruzar datos por persona, pero no necesita las cédulas. Reemplacen cada cédula por un token aleatorio, guarden la correspondencia aparte, y expliquen qué puede hacer un tercero con el archivo tokenizado y qué no.

ARCHIVO DE ANALÍTICA · UNA CÉDULA POR LÍNEA (DE EJEMPLO, FICTICIAS)

1015442387
1015442387
71298455
43876120



Las cédulas del ejemplo son inventadas

ARCHIVO QUE SE ENTREGA A ANALÍTICA

TABLA DE CORRESPONDENCIA · SE GUARDA APARTE, CON ACCESO RESTRINGIDO

Panel interactivo · ábralo en el navegador para ejecutarlo

Qué conserva y qué destruye la tokenización

Conserva la posibilidad de cruzar: la misma cédula produce siempre el mismo token, así que analítica puede contar cuántas operaciones hizo cada persona sin saber quién es. **Destruye** la posibilidad de identificar: el token es aleatorio y no tiene ninguna relación matemática con la cédula, así que del token no se vuelve a la cédula sin la tabla de correspondencia. Un tercero que reciba el archivo tokenizado puede hacer estadística, pero no puede señalar a nadie.

Es distinto de cifrar: un dato cifrado se puede descifrar con la llave, y dos datos iguales cifrados con modos que preservan patrones pueden delatarse. El token no se «descifra»: se busca en una tabla que vive en otro lugar, bajo otro control. Por eso es la respuesta correcta para un archivo que sale del área que lo custodia.

QUÉ SE ENTREGA DE ESTE EJERCICIO

- El archivo tokenizado y la tabla de correspondencia, por separado.
- **La respuesta que va directo a la entrega final:** qué puede hacer un tercero con el archivo tokenizado y qué no, y por qué esto es mejor que cifrar el campo.

REPASO · 5 MINUTOS

¿Qué técnica lo resuelve?

Seis situaciones de gestión de llaves y datos. Elijan la técnica adecuada.

1. Una llave crítica no debe quedar en manos de una sola persona, pero tampoco se puede exigir que estén las cinco a la vez para usarla.

2. Hay que cambiar la llave maestra sin volver a cifrar dos terabytes de base de datos.

3. Un archivo con cédulas sale hacia un área de analítica que necesita cruzar por persona, pero no identificarla.

4. Las llaves de los cajeros las cargó en 2019 una persona que ya no trabaja allí, sin custodios ni registro.

5. Un pagaré firmado hoy debe seguir siendo verificable en 2039, cuando los algoritmos de hoy podrían estar en desuso.

6. Se quiere poder demostrar que rotar llaves con periodicidad es viable y barato, ante quien dice que es imposible.

CIERRE

Qué se entrega y cómo se califica

Una página por equipo con los tres resultados y, sobre todo, la respuesta del ejercicio 3, que va directo a la recomendación de la entrega final.

- ☐ La reconstrucción de Shamir con tres partes y el resultado con dos.
- ☐ Los dos números de la rotación: bytes cambiados frente a datos totales.
- ☐ El archivo tokenizado y su tabla de correspondencia.
- ☐ La respuesta sobre qué puede y qué no puede hacer un tercero con el archivo tokenizado.
- ☐ Una frase que ate los tres a sus hallazgos: H6 los cajeros, la rotación la llave maestra, la tokenización el archivo que sale del área.

Con esto se cierra el módulo. Los seis laboratorios alimentan el informe de aseguramiento criptográfico de Coopaburrá. La sustentación ante el comité es el 8 de abril: lo que hoy es un ejercicio, allí es una recomendación con costo, plazo y responsable.

```
# pip install cryptography pycryptodome
import os, secrets
from Crypto.Protocol.SecretSharing import Shamir
from cryptography.hazmat.primitives.keywrap import aes_key_wrap, aes_key_unwrap

# 1 · repartir la llave de los cajeros: cinco custodios, umbral de tres
llave_cajeros = os.urandom(16)
partes = Shamir.split(3, 5, llave_cajeros)
assert Shamir.combine(partes[:3]) == llave_cajeros      # tres partes bastan

# 2 · rotar la llave maestra sin recifrar los datos
kek_vieja, kek_nueva = os.urandom(32), os.urandom(32)
dek_envuelta = aes_key_wrap(kek_vieja, os.urandom(32))
dek_rotada    = aes_key_wrap(kek_nueva, aes_key_unwrap(kek_vieja, dek_envuelta))
# cambiaron 40 bytes; ni un registro se recifro

# 3 · tokenizar una cedula sin relacion con el valor original
token = secrets.token_hex(8)                          # sustituto aleatorio
correspondencia = {token: "1015442387"}               # se guarda aparte, con acceso restringido
```